

Формальные модели безопасности

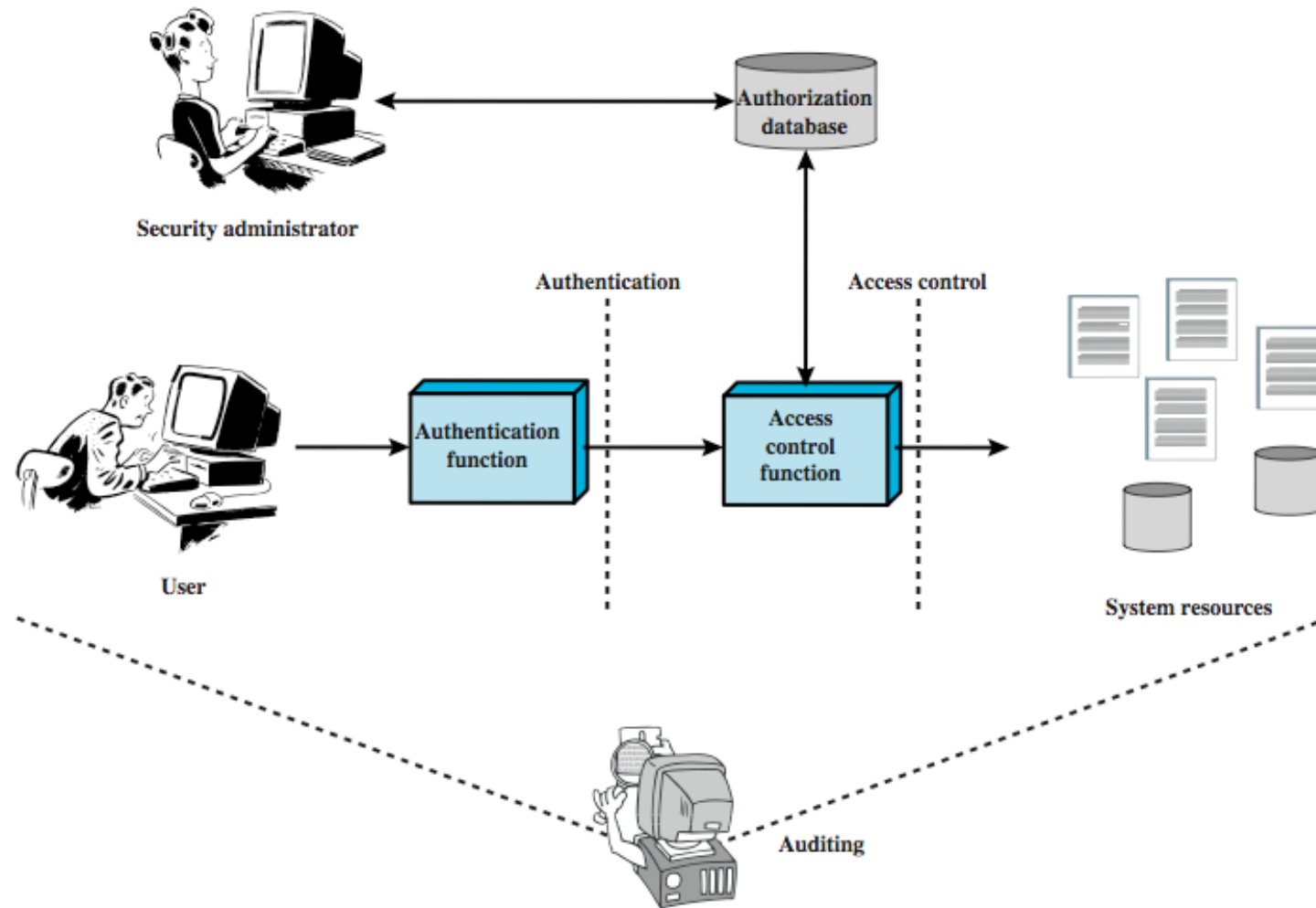
Промыслов Виталий Георгиевич

vitaly.promyslov@gmail.com

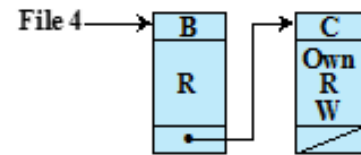
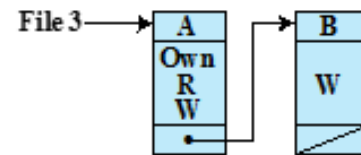
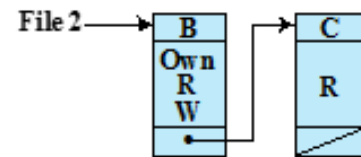
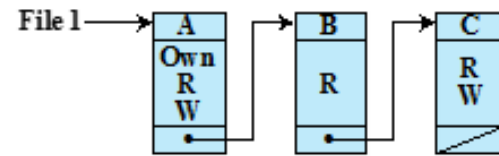
Литература

-
- **Основная:**
- Девянин П. Н. Модели безопасности компьютерных систем.. Учеб. пособие для вузов. Москва: Академия, 2005. 144 с.
- **Дополнительная:**
- Trusted Computer System Evaluation Criteria (TCSEC), DoD 5200.28-STD Supersedes CSC-STD-001-83, dtd 15 Aug 83 Library No. S225,711. <https://csrc.nist.gov/csrc/media/publications/conference-paper/1998/10/08/proceedings-of-the-21st-nissc-1998/documents/early-cs-papers/dod85.pdf>
- IEEE Computer, Volume 29, Number 2, February 1996, pages 38-47. Role-Based Access Control Models Ravi S. Sandhu', Edward J. Coynek, Hal L. Feinstein and Charles E. Youmank] Bishop M. Computer Security: Art and Science // Boston:Addison Wesley. 2003
- Eduardo B. Fernandez, Jie Wu, and Minjie H. Fernandez. User group structures in object-oriented database authorization. In J. Biskup, M. Morgerstern, and C. Landwehr, editors, Database Security VIII: Status and Prospects. North-Holland, 1995 .
- Coyne, E. Role engineering. In Proceedings of the first ACM Workshop on Role based access control (RBAC 95)*
- Role Prediction Using Electronic Medical Record System Audits. WenZhang, Carl A. Gunter,David Liebovitz,Jian Tian,and Bradley Malin AMIA 2011 Annual Symposium, Washington, DC, October 2011*
- *литература расширяющая материал лекции

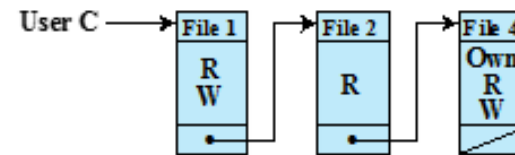
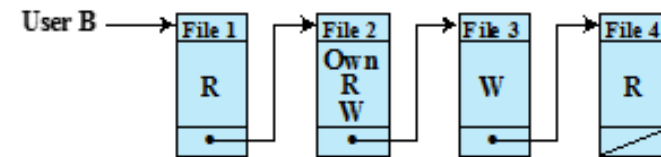
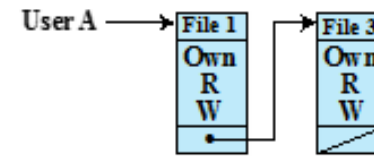
Основные принципы управления доступом



Структура матрицы доступа

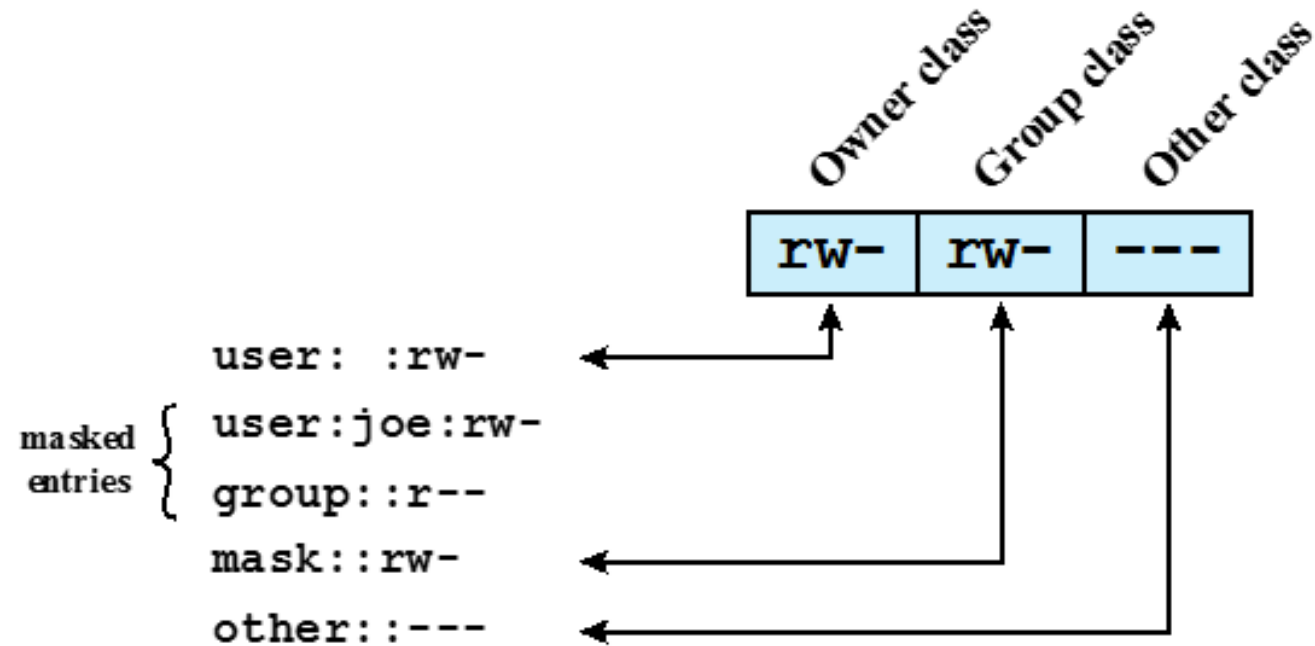


(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

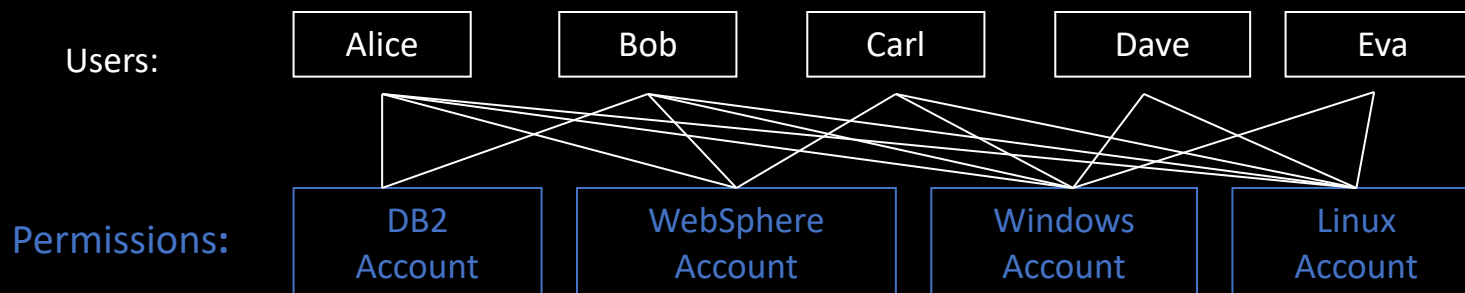
UNIX extended access control list



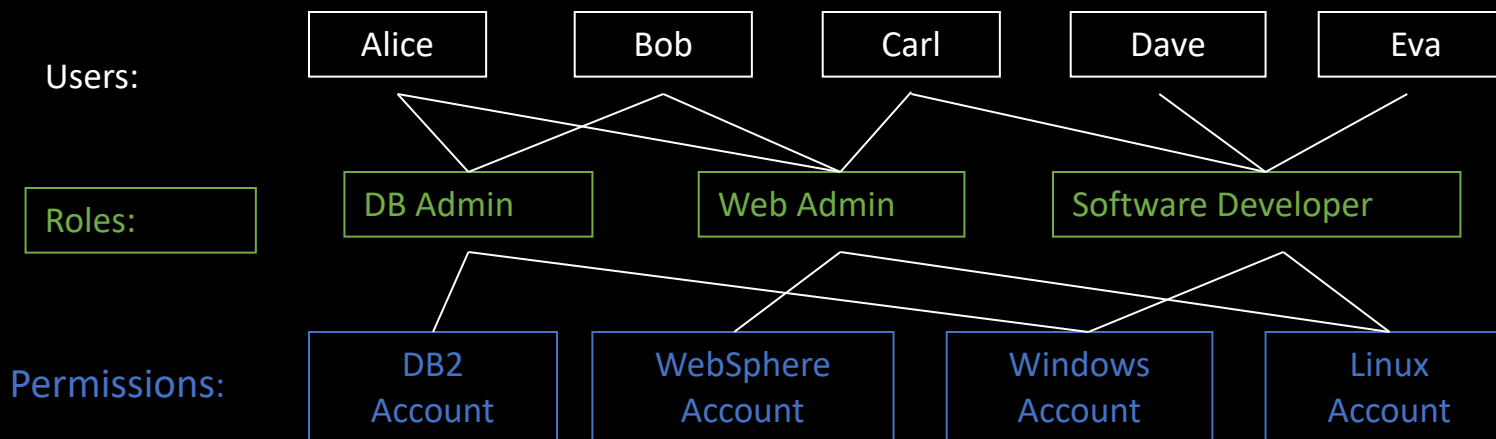
(b) Extended access control list

Доступ на основе ролей (RBAC)

без ролей



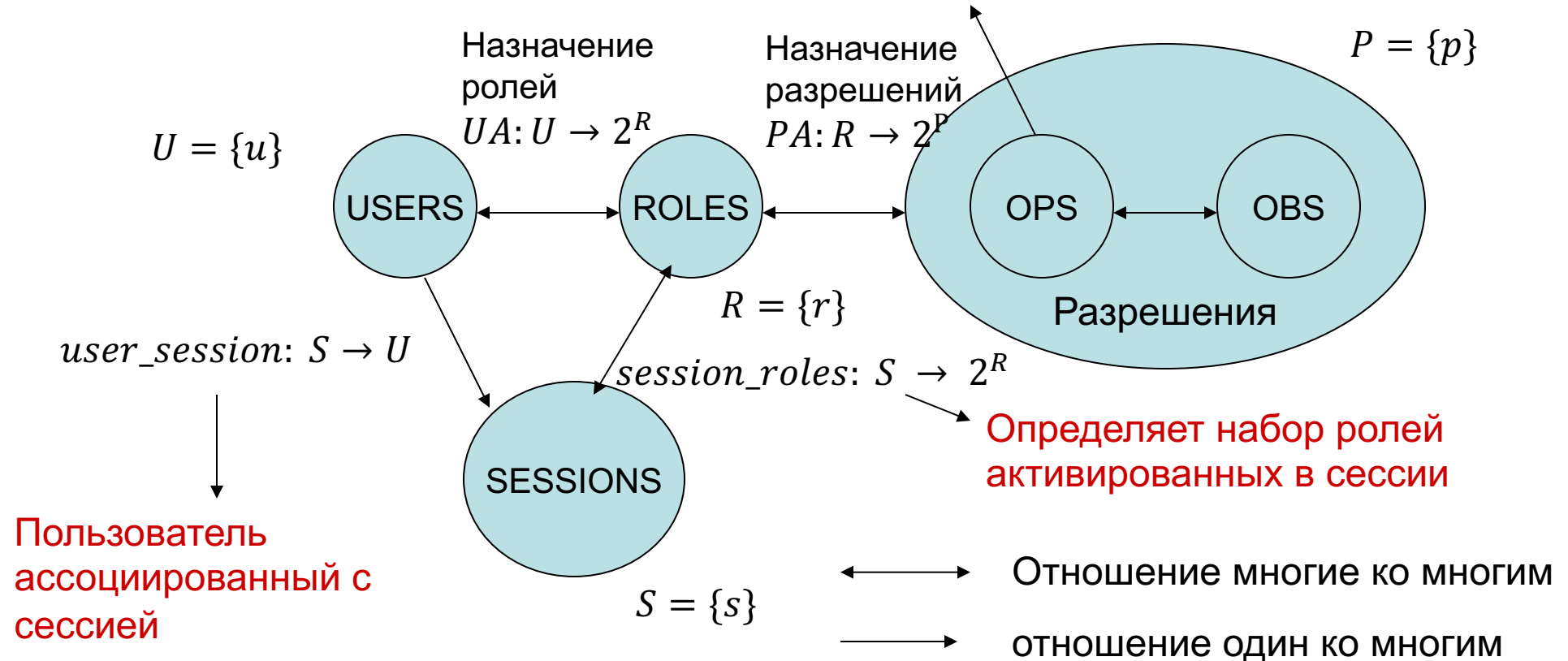
С ролями



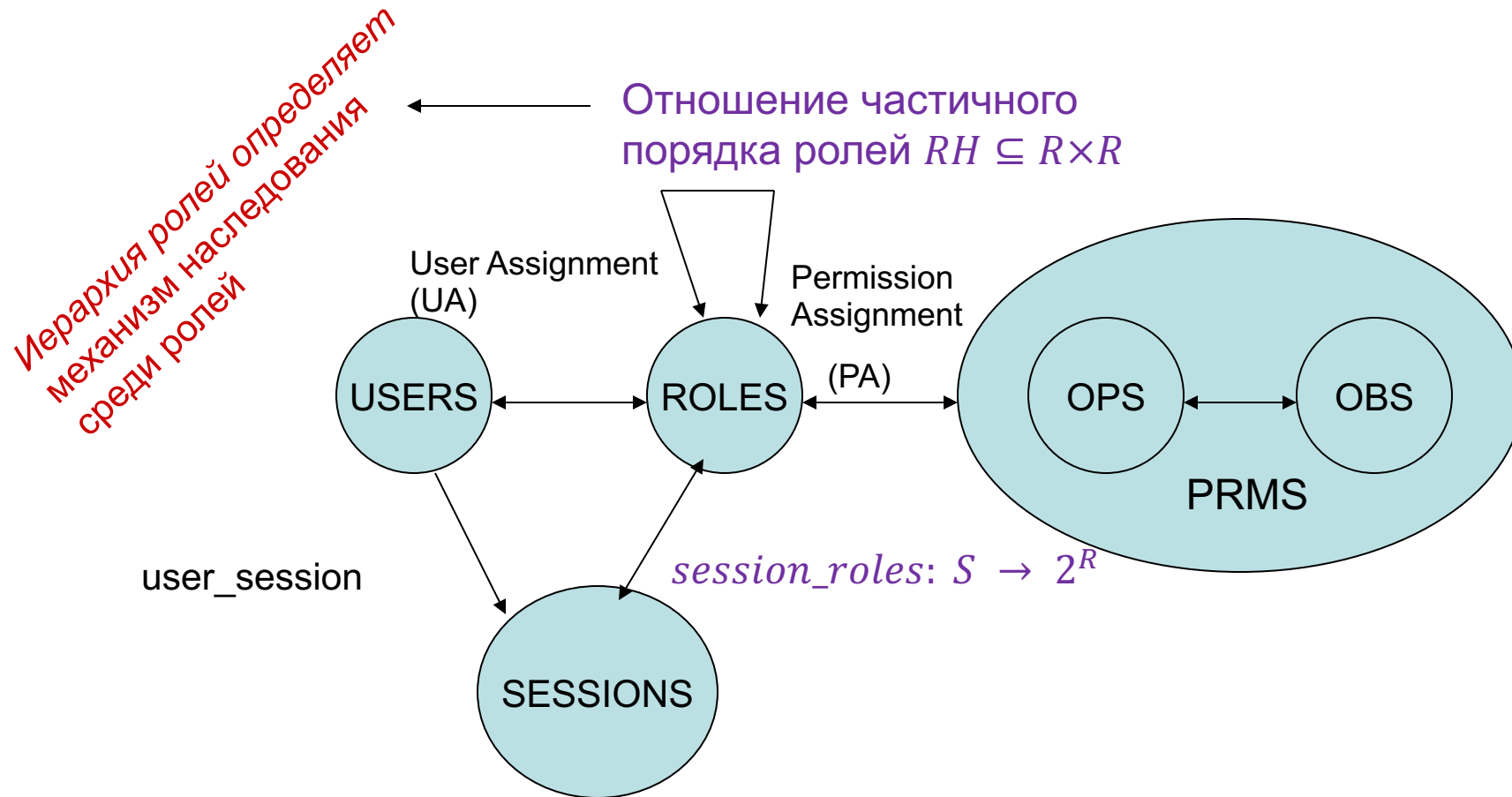
Базовая модель РРД (RBAC0)

Операции: read, write, execute

DBMS Операции : Insert, delete, append, update



Иерархия ролей в РРД (RBAC1)



Пример: RBAC для банка

- В имеет больше прав чем А
- Наследование упрощает таблицу ролей

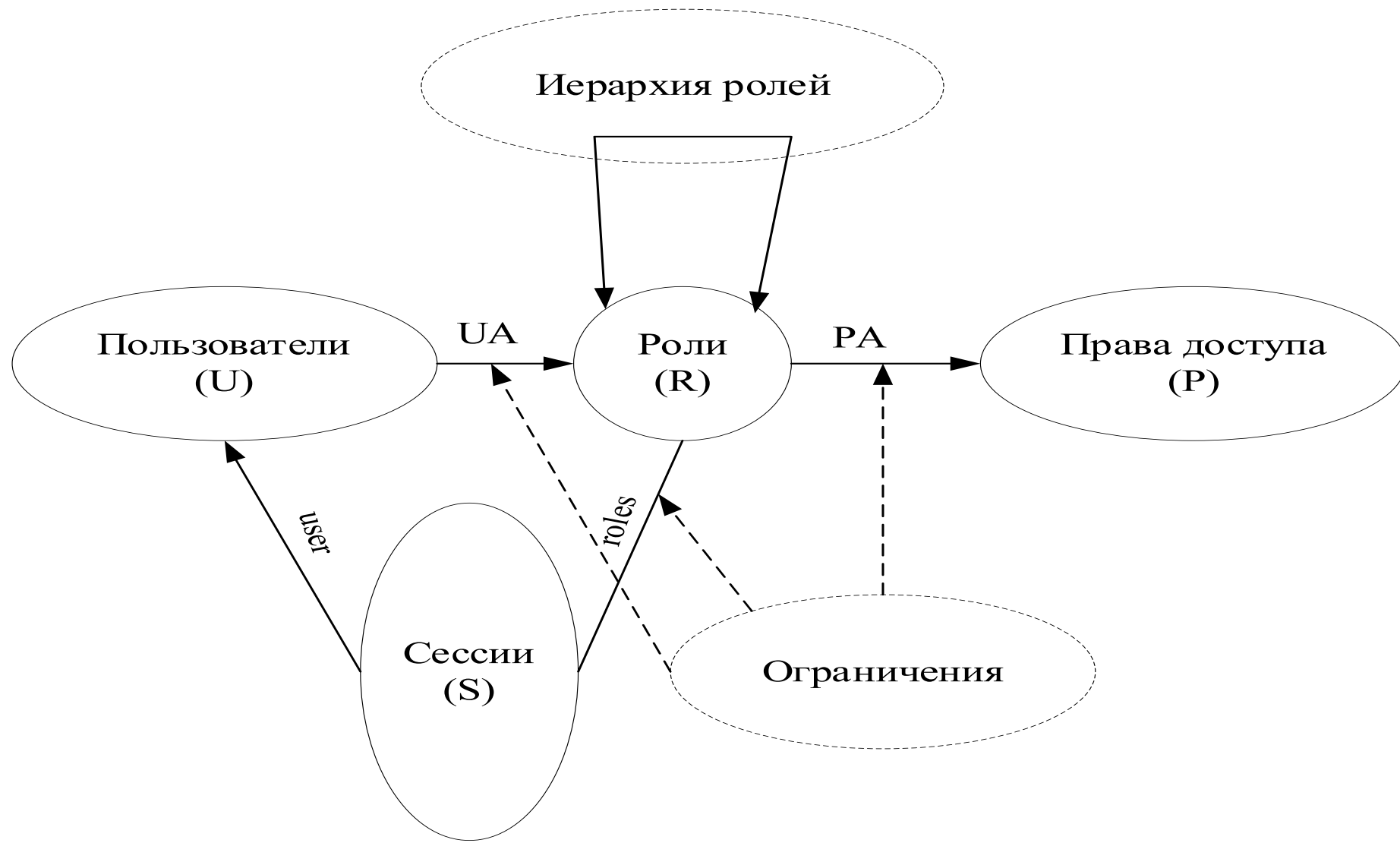
(b) Permission Assignments

Role	Application	Access Right
A	money market instruments	1, 2, 3, 4
	derivatives trading	1, 2, 3, 7, 10, 12
	interest instruments	1, 4, 8, 12, 14, 16
B	money market instruments	1, 2, 3, 4, 7
	derivatives trading	1, 2, 3, 7, 10, 12, 14
	interest instruments	1, 4, 8, 12, 14, 16
	private consumer instruments	1, 2, 4, 7
...	...	...

(c) PA with Inheritance

Role	Application	Access Right
A	money market instruments	1, 2, 3, 4
	derivatives trading	1, 2, 3, 7, 10, 12
	interest instruments	1, 4, 8, 12, 14, 16
B	money market instruments	7
	derivatives trading	14
	private consumer instruments	1, 2, 4, 7
...	...	...

RBAC2



Ограничения статического взаимного исключения ролей или прав доступа

В модели RBAC2 заданы ограничения статического взаимного исключения ролей или разрешений, если выполняются условия:

-
- $R = R_1 \cup \dots \cup R_n$ где $R_i \cap R_j = \emptyset$, для $1 \leq i \leq j \leq n$;
- $|UA(u) \cap R_j| \leq 1$ для $u \in U, i \in 1, 2, \dots, n]$
- $P = P_1 \cup \dots \cup P_m$ где $P_i \cap P_j = \emptyset$, для $1 \leq i \leq j \leq m$;
- $|PA(r) \cap P_j| \leq 1$ для $p \in P, i \in 1, 2, \dots, m$

Ограничение на мощность множества

В модели RBAC2 заданы статические количественные ограничения на обладание **ролью** или **разрешением**, если определены две функции:

- $\alpha: R \rightarrow N_0$
- $\beta: P \rightarrow N_0$,
- $|UA^{-1}(r)| \leq \alpha(r), r \in R$
- $|PA^{-1}(p)| \leq \beta(p), p \in P$

Задано **динамическое** ограничение на обладание ролью, если определена функция

- $\gamma: R \rightarrow N_0$, и выполняется условие:
- $|session_roles^{-1}(r)| \leq \gamma(r), r \in R$

Ограничения необходимого обладания ролью или разрешением

В модели RBAC2 заданы **статические** ограничения необходимого обладания ролью или разрешением, если :

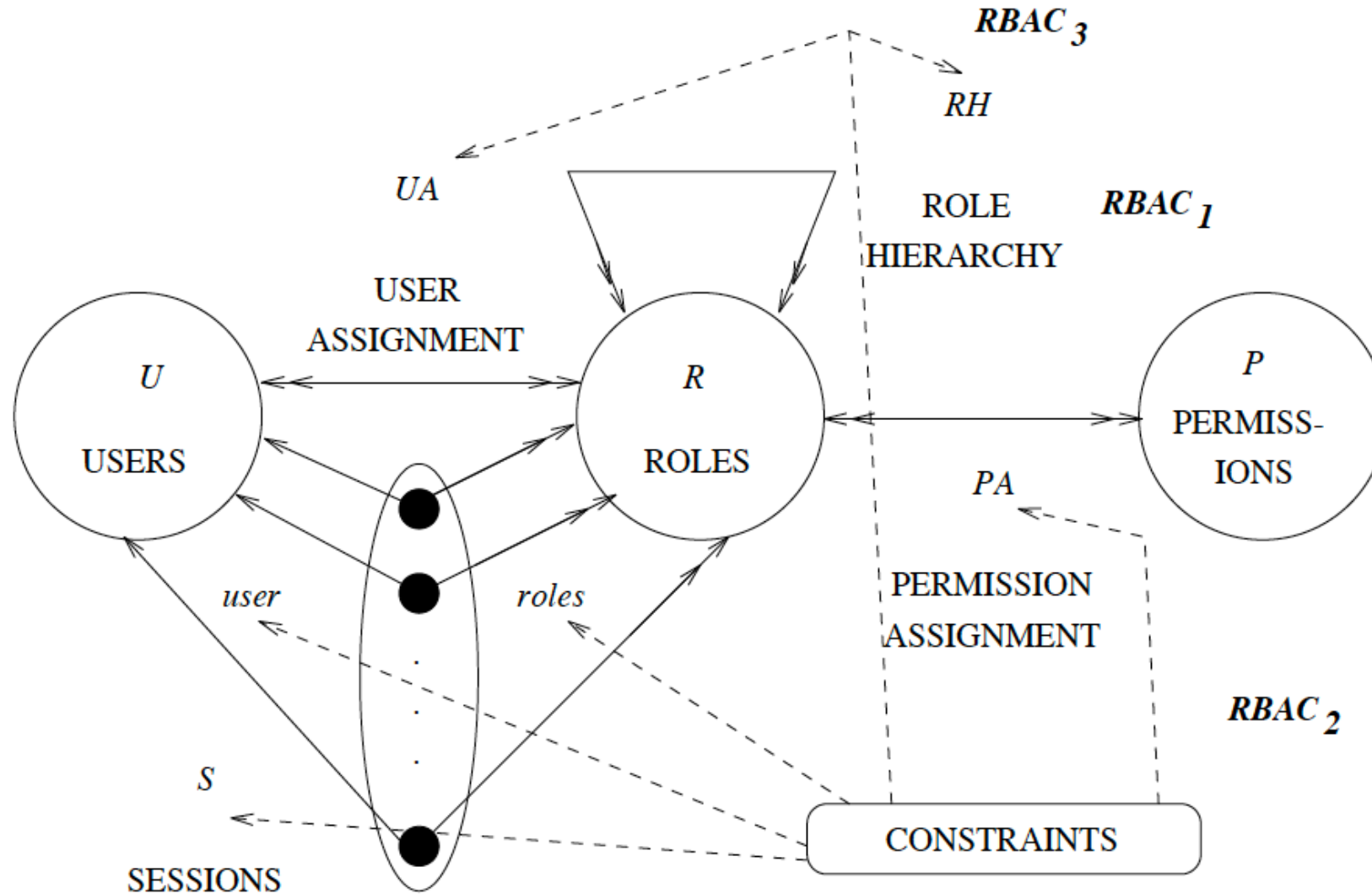
- $\alpha: R \rightarrow 2^R$
- $\beta: P \rightarrow 2^P$ и выполняются условия:
- для $u \in U$ если $r, r' \in R, r \in UA(u)$ и $r' \in \alpha(r)$, то $r' \in UA(u)$;
- для $r \in R$ если $p, p' \in P, p \in PA(r)$ и $p' \in \beta(p)$, то $p' \in PA(r)$;

В модели задано **динамическое** ограничение для обладания ролью, если

$\gamma: R \rightarrow 2^R$ и выполняется условие для:

- $s \in S$, если $r, r' \in R, r \in session_roles(s)$ и $r' \in \gamma(r)$, то $r' \in session_roles(s)$.

Объединяющая модель РРД (RBAC3)



Представление РРД в матрице доступов

	R ₁	R ₂	...	R _n
U ₁	×			
U ₂	×			
U ₃		×		×
U ₄				×
U ₅				×
U ₆				×
...				
U _m	×			

(Users, Roles)

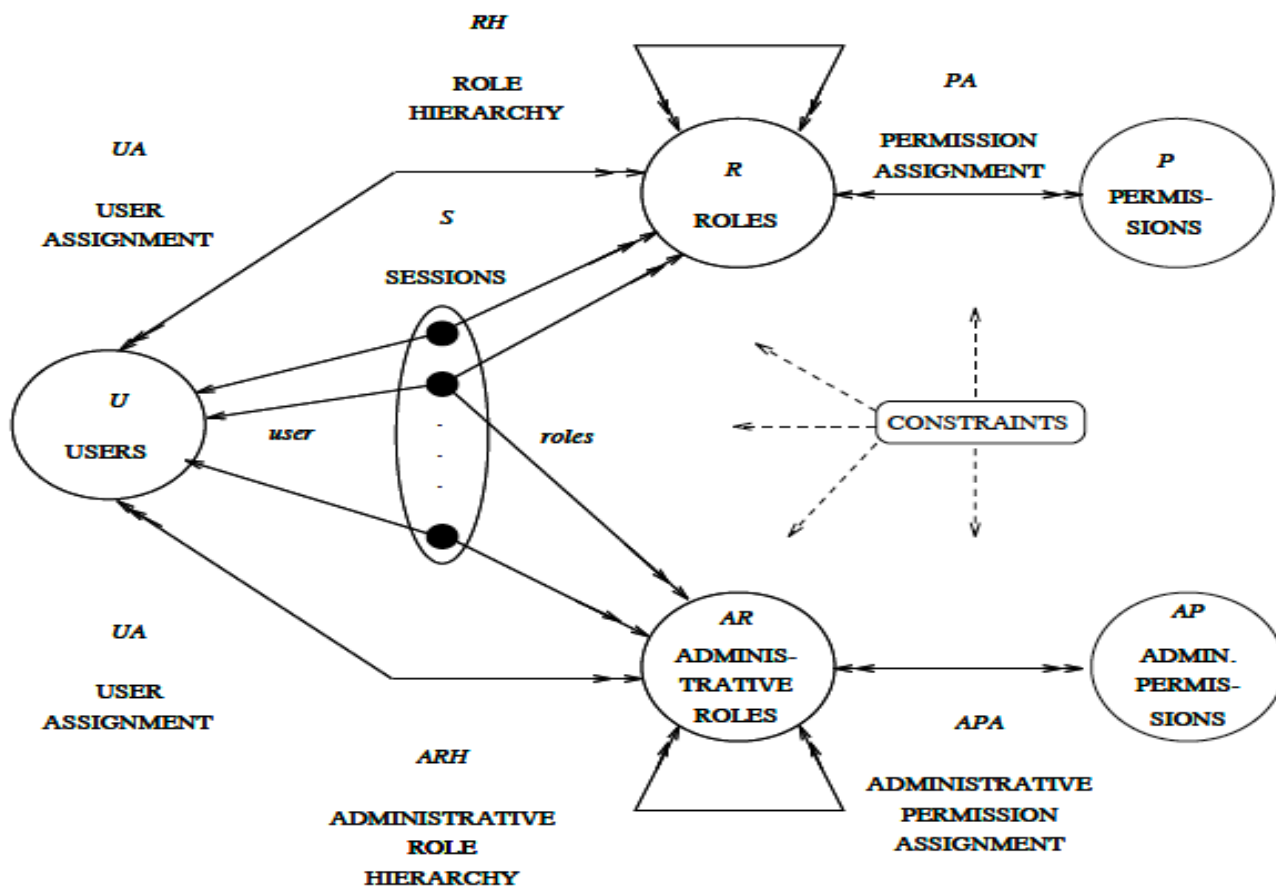
		OBJECTS								
		R ₁	R ₂	R _n	F ₁	F ₁	P ₁	P ₂	D ₁	D ₂
ROLES	R ₁	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
	R ₂		control		write *	execute			owner	seek *
	•									
	•									
	R _n			control		write	stop			

(Roles, Objects)

- Similar to DAC ACM

- Roles can be
Objects

Модель администрирования РРД



Административные полномочия в RBAC можно рассматривать как возможность:

- изменять назначение пользователей,
- назначение разрешений
- отношения иерархии ролей.

Figure 4: RBAC Administrative Model

- [Eduardo B. Fernandez et al, Database Security VIII: Status and Prospects. North-Holland, 1995]

Элементы администрирования РРД

- $AR = \{r\}$ – множество административных ролей $AR \cap R = \emptyset$;
- $AP = \{p\}$ – множество административных разрешений $AP \cap P = \emptyset$;
- $APA: AR \rightarrow 2^{AP}$ – отношение, определяющая для каждой административной роли множество административных прав доступа; при этом для каждого $p \in AP$ существует $r \in AR$ такая, что $p \in APA(r)$
- $AUA: U \rightarrow 2^{AR}$ – отношение, определяющее для каждого пользователя множество административных ролей, на которые он может быть авторизован.

• $usersession: S \rightarrow 2^{AR} \cup 2^R$ – функция, определяющая для пользователя множество всех (административных и обычных) ролей, на которые он авторизован в данной сессии; при этом в каждый момент времени для каждого $s \in S$ выполняется условие $session_roles \subseteq UAusersessions \cup AUAusersessions$.

Группы административных ролей

Иерархией (административных) ролей в модели администрирования РРД называется заданное на множестве ролей AR отношение частичного порядка « $\leq$ ». При этом выполняется условие для $u \in U$, если $r, r' \in AR$, $r \in AUA(u)$ и $r' \leq r$, то $r' \in AUA(u)$.

- Администрирование множеств авторизованных ролей пользователей (UA);
- Администрирование множеств разрешений, которыми обладают роли (PA);
- Администрирование иерархии ролей (RH).

Администрирование множеств авторизованных ролей пользователей

Для администрирования ролей необходимо определить:

- для каждой административной роли множество ролей, множества авторизованных пользователей которых она позволяет изменять;
- для каждой роли предварительное условие, которому должны соответствовать пользователи, прежде чем они будут включены во множество ее авторизованных пользователей

Предварительным условием для роли $r \in R$ называется булева функция $cr(u) = cr(x_1(u), \dots, x_k(u))$, где $u \in U$, $x_1, \dots, x_k \in R$ и $cr(x_1(u), \dots, x_k(u))$ — булева функция от k булевых переменных и роль $r \in R$ может быть включена во множество авторизованных ролей пользователя $u \in U$ если $cr(u) = true$.

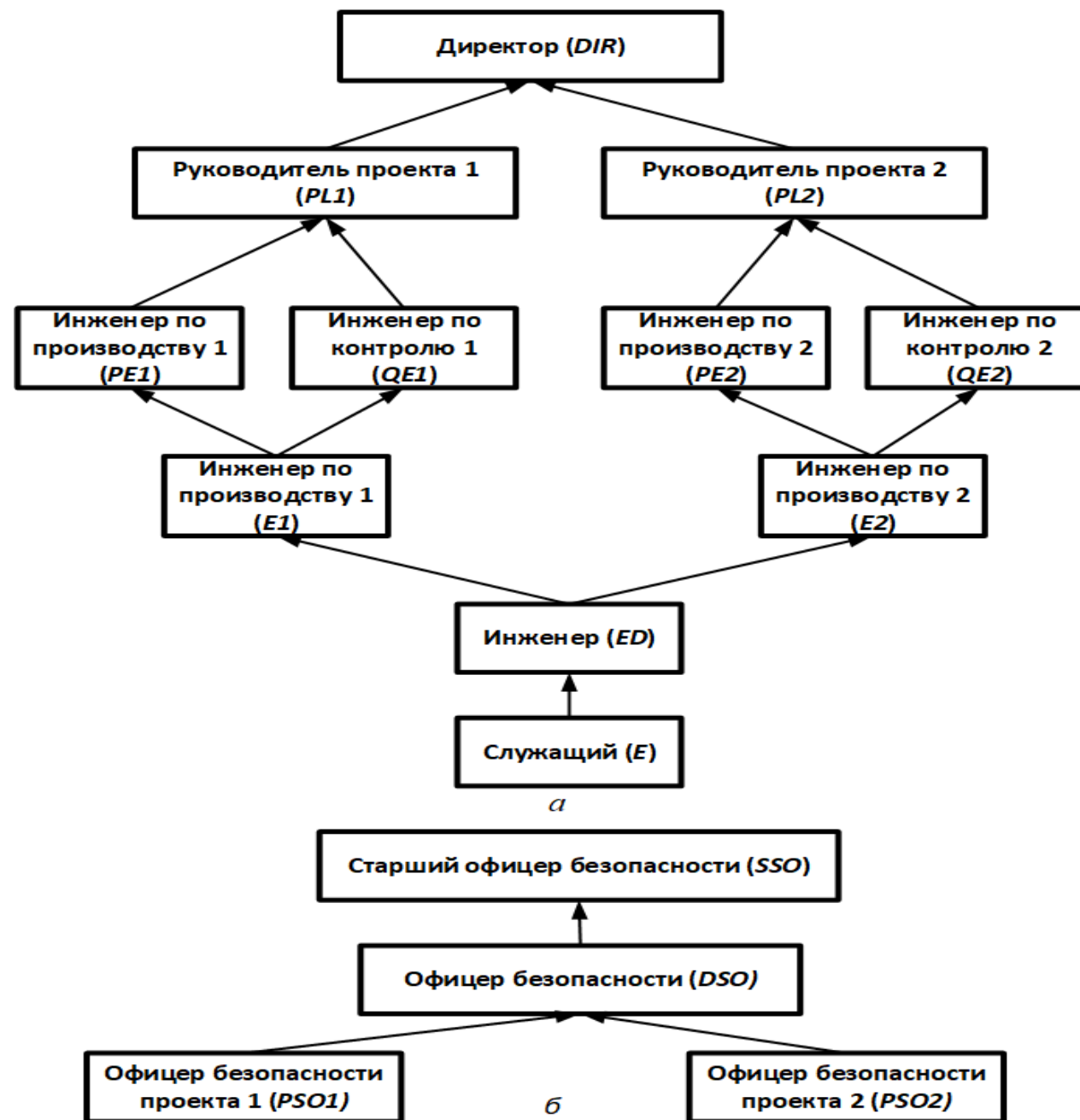
Функции администрирования множеств авторизованных ролей пользователей

- *can-assign*: $AR \rightarrow CR \times 2^R$ — отношение, определяющая для каждой административной роли множество ролей, которые могут быть включены во множество ролей пользователя с использованием данной административной роли при выполнении заданных предварительных условий;
- *can-revoke*: $AR \rightarrow 2^R$ — отношение, определяющая для каждой административной роли множество ролей, которые могут быть исключены из множества авторизованных ролей пользователя с использованием данной административной роли.

Администрирование множеств разрешений, которыми обладают роли

- $can_assign_p: AR \rightarrow CR_p \times 2^R$ – отношение, определяющая для каждой административной роли множество ролей, для которых разрешено включать разрешения в множества разрешений с использованием данной административной роли при выполнении заданных предварительных условий;
- $can_revoke_p: AR \rightarrow 2^R$ – отношение, определяющая для каждой административной роли множество ролей, для которых разрешено удаление прав доступа из множеств прав доступа с использованием данной административной роли.

Пример



Пример (см рис выше)

Добавление разрешений *can – assign_p*

Административная роль	Предварительное условие	Диапазон ролей
<i>CSO</i>	-	$[E, DIR]$
<i>DSO</i>	<i>DIR</i>	$[PL1, PL1]$
<i>DSO</i>	<i>DIR</i>	$[PL2, PL2]$
<i>PSO1</i>	$PL1$ and (not $QE1$)	$[PE1, PE1]$
<i>PSO1</i>	$PL1$ and (not $PE1$)	$[QE1, QE1]$
<i>PSO2</i>	$PL2$ and (not $QE2$)	$[PE2, PE2]$
<i>PSO2</i>	$PL2$ and (not $PE2$)	$[QE2, QE2]$

Административная роль	Диапазон ролей
<i>CSO</i>	$[E, DIR]$
<i>DSO</i>	$[ED, DIR]$
<i>PSO1</i>	$[PE1, PE1]$
<i>PSO2</i>	$[PE2, PE2]$
<i>PSO1</i>	$[QE1, QE1]$
<i>PSO2</i>	$[QE2, QE2]$

Удаление разрешений *can – revoke_p*

Администрирование иерархии ролей

- Возможности – множества разрешений и возможностей;
 - Группы – множества пользователей и групп;
 - Объединения – множество возможностей, групп и объединений.
-
- Роли-возможности – роли, которые обладают только определенными в соответствующей возможности разрешениями
 - Роли-группы – роли, на которые могут быть авторизованы одновременно только все пользователи соответствующей группы.
 - Роли-объединения – роли, которые обладают только определенными возможностями и на которые могут быть авторизованы группы пользователей.

Отношение частичного порядка $\leq$ на множестве ролей-объединений

Роль-объединение r_1 , в иерархии ролей превосходит роль-объединение r_2 , если выполняются условия:

- Возможности роли r_2 , являются подмножеством возможностей роли r_1 ;
- Пользователи и группы пользователей, которые могут быть авторизованы на роль r_1 , являются подмножеством множества пользователей и групп пользователей, которые могут быть авторизованы на роль r_2 .

Функции администрирования возможностей

- $can_assign_a : AR \rightarrow CRa \times 2^{UPR}$ — отношение, определяющая для каждой административной роли множество ролей-объединений, во множество разрешений которых возможно включать новые возможности с использованием данной административной роли при выполнении заданных предварительных условий;
- $can_revoke_a : AR \rightarrow 2^{UPR}$ — отношение, определяющая для каждой административной роли множество ролей-объединений, из множества разрешений которых возможно удаление возможностей с использованием данной административной роли;

Функции администрирования групп пользователей

- $can_assign_g : AR \rightarrow CR_g \times 2^{UPR}$ – отношение, определяющая для каждой административной роли множество ролей-объединений, которые разрешено включать во множество авторизованных ролей групп пользователей с использованием данной административной роли при выполнении заданных предварительных условий;
- $can_revoke_g : AR \rightarrow 2^{UPR}$ – отношение, определяющая для каждой административной роли множество ролей-объединений, которые разрешено удалять из множества авторизованных ролей групп пользователей с использованием данной административной роли.

Администрирования иерархии ролей

$can-modify:AR \rightarrow 2^R$ – отношение, определяющая для каждой административной роли интервал ролей, на котором возможно изменение иерархии ролей с использованием данной административной роли.

Инженерия ролей в РРД

- Сбор информации о деятельности предприятия и обязанностей работников;
- Выделение кластеров однотипных обязанностей;
- Идентификация кластеров;
- Составление описания кластеров;
- Удаление дублицирующих обязанностей, если таковые выявлены;
- Определение минимального набора разрешений для каждой роли;
- Проигрывание ролей для верификации назначенного набора разрешений;
- Составление иерархии ролей.

[C96] Coyne, E. Role engineering. In Proceedings of the first ACM Workshop on Role based access control (RBAC 95)

[Z+11] Role Prediction Using Electronic Medical Record System Audits. WenZhang, Carl A. Gunter, David Liebovitz, Jian Tian, and Bradley Malin AMIA 2011 Annual Symposium, Washington, DC, October 2011

Язык описания политики авторизации и ролей (AWS Cedar)

Структура политики Cedar:

- **Эффект** (Effect)— либо **разрешить** (Permit), либо **запретить** (Forbid). Все запросы по умолчанию отклоняются.
- **Область действия политики** (Policy scope) — описывает **принципала** (Principal), **действие** (Action) и **ресурс** (Resource), к которым применяется политика, частично на основе роли или членства в группе.
- **Условие** (Condition) — позволяет добавлять более детальные разрешения, добавляя к ним общие условия. Это актуально для политик управления доступом на основе атрибутов (ABAC), где можно добавить контекст и атрибуты.

Немного реальных РРД

Numbers

- 65 official positions, 368 job functions
- 50,659 employees
- 1300 roles (potentially 23,920)
 - Agrees with estimate – #roles is 3-4% of #users
- 42,000 security profiles distributed daily

Реализация модели мандатного доступа в РРД

- U — множество пользователей (субъектов);
- O — множество объектов;
- $(L, \leq)$ — решетка уровней конфиденциальности, например:
- $L = \{\text{Low}\{\text{unclassified}\}, \text{Medium}\{\text{confidential}\}, \text{High}\{\text{secret}\}\}$ где $\text{Low} < \text{Medium} < \text{High}$
- Функция s , определяющая $s: U \rightarrow L$ — уровень доступа пользователя; $s: O \rightarrow L$ — уровень конфиденциальности объекта;
- $A = \{\text{Read}, \text{Write}\}$ — множество доступов

Реализация модели мандатного доступа в РРД

- **Определение 5.18.** Доступ (u, o, r) является безопасным для **либерального** мандатного разграничения доступа, если выполняется одно из условий:;
 - $r = \text{read}$ и $c(u) \geq c(o)$ - (ss-свойство);
 - $r = \text{write}$ и, если существует доступ (u, o', read) , то $c(o) \geq c(o')$ (либеральное *-свойство).
 -
- **Определение 5.19.** Доступ (u, o, r) является безопасным для **строого** мандатного разграничения доступа, если выполняется одно из условий:
 - $r = \text{read}$ и $c(u) \geq c(o)$ - (ss-свойство);
 - $r = \text{write}$ и, если существует доступ (u, o', read) , то $c(o) = c(o')$ (строгое *-свойство).

Реализация модели мандатного доступа в РРД

- Пусть:
- $R = \{x_read \mid x \in L\} \cup \{x_write \mid x \in L\}$, — множество ролей;
- $P = \{(o, read) \mid o \in O\} \cup \{(o, write) \mid o \in O\}$ — множество разрешений (прав доступа).
- Зададим на множестве ролей R иерархию, при этом иерархии ролей на множествах $\{x_read \mid x \in L\}, \{x_write \mid x \in L\}$, будут независимы.

Реализация модели мандатного доступа в РРД

- **Определение 5.20.** Иерархией на множестве ролей R в соответствии с требованиями **либерального** мандатного разграничения доступа называется отношение частичного порядка « $\leq$ », где для $r, r' \in R$ справедливо неравенство $r \leq r'$, если выполняется одно из условий:
 - $r = x_read, r' = x'_read$ и $x \leq x'$; $x', x \in L$
 - $r = x_write, r' = x'_write$ и $x' \leq x$; $x', x \in L$

Формальная реализация MAC в RBAC (либеральное *-свойство)

$R = \{HR, M1R, M2R, LR, HW, M1W, M2W, LW\}$

- RH либеральное *-свойство
- $P = [(o, r), (o, w) \mid o - \text{объект в системе}]$
- Ограничение на UA: каждому пользователю назначается ровно одна роль xR и всем максимальные роли записи (в данном случае одиночная роль LW)
- Ограничение на сеансы: каждый сеанс имеет ровно две роли yR и yW
- Ограничения на PA:
 - - (o, r) присваивается роли xR , если доступ (o, w) присвоен роли xW
 - - (o, r) назначена ровно для одной роли xR

Реализация модели мандатного доступа в РРД

- **Определение 5.21.** Иерархией на множестве ролей R в соответствии с требованиями **строгого** мандатного разграничения доступа называется отношение частичного порядка « $\leq$ », где для $r, r' \in R$ с справедливо неравенство $r \leq r'$, если выполняется одно из условий:
 - $r = x_read, r' = x_read'$ и $x \leq x'$; $x', x \in L$
 - $r = x_write, r' = x_write'$ и $x' = x$; $x', x \in L$

Формальная реализация МАС в RBAC (строгое *-свойство)

$R = \{HR, M1R, M2R, LR, HW, M1W, M2W, LW\}$

- RH, как показано на рисунке либеральное *-свойство
- $P = \{(o, r), (o, w) \mid o - \text{объект в системе}\}$
- Ограничение на UA: каждому пользователю назначается ровно одна роль xR
- Каждому пользователю в UA назначаются все роли формы yW (поскольку все они теперь максимальные роли). Разрешение (o, w) больше не наследуется другими ролями, как в случае либерального свойства
- Ограничение на сеансы: каждый сеанс имеет ровно две роли yR и yW
- Ограничения на RA:
 - - (o, r) присваивается xR, если (o, w) присваивается xW
 - - (o, r) назначена ровно для одной роли xR

RBAC3 для композитной решетки с либеральными версиями MAC

- Множество ролей $R = \{HSR-LIR, HSR-HIR, LSR-LIR, LSR-HIR, LSW-HIW, HSW-HIW, LSW-LIW, HSW-LIW\}$;
- Иерархия ролей HR , как показано на рисунке (Рисунок вверху);
- Множество разрешений $P = \{(o, r), (o, w)\}$: разрешения назначаются на каждый индивидуальный объект $o \in O_1$ т.е. на каждый объект есть свое разрешение по чтению и на запись;
- Ограничение на UA : каждому пользователю назначается ровно одна роль $xSR-yIR$ и всем максимальные роли записи (в данном случае одиночная роль $LSW-HIW$), в этом случае максимальная роль по записи наследует все разрешения более низких в иерархии ролей по записи;
- Ограничение на сеансы S : каждый сеанс имеет ровно две роли $uSR-vIR$ и $uSW-vIW$ т.е. пользователь в сеансе, активирует роль по записи для которой уровень доступа по чтению равен u, v .
- Ограничения на PA :
 - Разрешение r присваивается роли $xSR-yIR$, если разрешение w присвоено роли $xSW-yIW$,
 - Разрешение r назначено ровно для одной роли $xSR-yIR$.

Иерархия ролей РРД для либеральной версии мандатных моделей, которые ориентированы на сохранения целостности и конфиденциальности

